

Herramientas de Hacking Ético para contraseñas y detección de vulnerabilidades

Brandon Rodrigo Méndez Méndez

Benemérita Universidad Autónoma de Puebla

Facultad de Ciencias de la Computación

23 de octubre del 2025

Periodo Otoño 2025

Resumen. En este trabajo de investigación se detalla el uso de tres herramientas de uso profesional de la seguridad. El objetivo es desglosar su funcionamiento, sus aplicaciones prácticas, ventajas y desventajas.

Palabras Clave: Pentester, Protocolo, Hydra, SSH, FTP, Pentesting, RDP, Pentester. Hacking, Fuerza Bruta, Hashes NTLM, Mimikatz, Pass-the-Hash, Pass-the-Ticket, Kerberos, sistema, ciberseguridad, antivirus, framework, vulnerabilidades, exploits, Payloads, meterpreter, parches, actualizaciones, seguridad, Hardening, DAST, pipelines, Hardening.

1 Introducción

En el actual mundo digital donde la mayoría de nuestra información es una de las cosas más importante que tenemos, la ciberseguridad se ha vuelto en un punto fundamental para mantener la integridad de está misma. Actualmente el creciente numero de ciberataques bien ejecutados, ha obligado a los encargados de sobre guardar la información de distintas organizaciones no solo ha prevenir implementando defensas solidas si no a corroborarlas activamente.

Aquí es donde entra el hacking ético, ya que juega un papel crucial ya que son los encargados de testear y utilizar herramientas y técnicas que cualquier atacante podría realizar, pero todo esto se lleva a cabo con permisos previamente dados por los propietarios de sistema, todo esto con un solo objetivo que es el de encontrar vulnerabilidades y así poder solucionarlas y evitar ataques que podrían comprometer información sensible. A continuación se muestra un análisis detallado del uso de tres herramientas que tienen una gran importancia para prevenir este tipo de ataques.

Hydra (THC – Hydra)

Hydra es una de las herramientas de hacking más utilizadas ya que nos permite realizar ataques de fuerza bruta de manera online. A comparación de herramientas como John The Ripper o HashCat que funcionan de manera offline es decir que trabajan sobre hashes con los que ya contamos. Hydra actúa de forma que intenta adivinar las contraseñas objetivo probando muchos tipos de combinaciones de usuarios y contraseñas diferentes de forma rápida y paralela conectándose por medio de servicio en la red, como lo puede ser un login de algún sitio web o por medio de protocolos de red como SSH y FTP. [1]

1.1 Usos y Aplicaciones

Hydra tiene bastantes usos, pero uno de sus usos principales es el auditar la seguridad y robustez de las contraseñas de algún tipo de servicio que pueda estar expuesto.

Pruebas de Penetración (Pentesting): Estas pruebas sirven para comprobar si existen contraseñas que puedan ser débiles en servicios como:

- **SSH, FTP, Telnet:** Son puertas de entrada para administrar servidores. Si Hydra encuentra que el usuario root tiene la contraseña 123456, el pentester gana control total del servidor.
- **Servicios de correo (POP3, IMAP, SMTP):** Estos tres son los protocolos que usan los clientes de correo para hablar con el servidor de correo.
- **Bases de datos:** Si se deja alguna base de datos expuesta. Un pentester usaría Hydra para ver si el usuario root de la base de datos tiene una contraseña en blanco o débil. Si entra, puede comprometer información confidencial.
- **Servicios de Windows (SMB, RDP):** RDP es el Escritorio Remoto. Si Hydra encuentra que el Administrator tiene la contraseña Empresa2025, el pentester puede ver el escritorio del servidor como si estuviera sentado frente a él.
- **Formularios de login web:** Este es el más común. Es el panel de admin de un sitio web, tu correo web, o cualquier página que pida usuario y clave. Hydra automatiza el proceso de rellenar ese formulario miles de veces para lograr tener acceso al sitio.

Auditoría de Políticas: Demostrar el riesgo de no tener políticas de bloqueo de cuentas tras varios intentos fallidos. [2]

1.2 Ventajas

Versatilidad: Soporta una lista enorme de protocolos de red.

Velocidad: Es extremadamente rápida, ya que puede lanzar múltiples intentos de conexión en paralelo.

Flexibilidad: Permite usar listas de usuarios y listas de contraseñas o incluso generar contraseñas sobre la marcha.

1.3 Desventajas

Ruidosa: Genera una cantidad masiva de tráfico de red y entradas de log (registros). Es muy fácil de detectar por sistemas de detección de intrusos (IDS/IPS) o herramientas como *Fail2Ban*.

Dependiente del Entorno: Si el servicio bloquea la IP tras 3-5 intentos fallidos, Hydra se vuelve ineficaz.

No rompe hashes: Solo prueba credenciales contra un servicio vivo

1.4 ¿Cómo defenderse de Hydra?

El objetivo es hacer que el ataque de fuerza bruta sea inútil o imposible.

- **Política de Bloqueo de Cuentas:** Bloquear una cuenta o IP después de 5-10 intentos fallidos.
- **Autenticación de Múltiples Factores (2FA):** Requerir un código del teléfono además de la contraseña.
- **Usar CAPTCHA:** Añadir la prueba de No soy un robot en los formularios web para detener scripts.
- **Instalar Fail2Ban:** Usar un software que detecta y bloquea IPs que realizan ataques de fuerza bruta.

2 The Metasploit Framework

The Metasploit Framework, es muy conocida y utilizada por gente que está en el mundo de la ciberseguridad, ya que no es solo una herramienta sino que es una plataforma completa para todo el Desarrollo, pruebas y ejecución de exploits. Al ser un proyecto de código abierto significa que está constantemente en mantenimiento por la propia comunidad.

Unas de las principales funciones que tiene Metasploit Framework es el poder tomar la información de cierta o ciertas vulnerabilidades que se pudieron haber obtenido previamente para poder utilizar algún módulo de código y así poder aprovechar el o los fallos todo esto para poder obtener el acceso al sistema objetivo. [5]

2.1 Usos y aplicaciones

The Metasploit Framework es la principal herramienta para las fases de explotación y post-explotación en cualquier prueba de pentesting, a continuación listamos algunos de los principales usos de esta herramienta.

- **Validación de Vulnerabilidades:** Este es su uso más común, ya que después de realizar un escáner para reportar las vulnerabilidades más críticas, usamos Metasploit para demostrar que esas vulnerabilidades son realmente explotables.
- **Ejecución de Exploits:** Tiene una de las bases de datos de *exploits* públicos más grande y organizadas del mundo, lo que simplifica el trabajo, simplemente se busca la vulnerabilidad en cuestión y si existe un modelo adecuado, se configura el exploit y se utiliza.
- **Generación de Payloads:** Te permite crear payloads como un shell inverso meterpreter, que es lo que te da el control del sistema víctima una vez que el exploit funciona.
- **Post-Explotación:** Una vez que se tiene acceso, Metasploit ofrece módulos para escalar privilegios, moverse a otras máquinas, obtener contraseñas o demás.
- **Desarrollo de Exploits:** Los investigadores la usan para escribir y probar nuevos exploits para vulnerabilidades recién descubiertas. [6]

2.2 Ventajas

- **Es el Estándar de la Industria:** Todo profesional de ciberseguridad ofensiva debe conocer Metasploit
- **Modular y Flexible:** Su arquitectura te permite combinar exploits para poder entrar al sistema y a su vez, payloads que nos sirven ya una vez dentro y encoders para buscar código de una forma sencilla.
- **Código Abierto:** La versión Framework es gratuita y también es extremadamente potente.
- **Integración:** Se integra perfectamente con otras herramientas. Puedes importar los reportes de Nessus o Nmap a Metasploit para lanzar ataques automáticamente contra los objetivos encontrados.

2.3 Desventajas

- **Detectado por AV/EDR:** Al ser tan popular, *todos* los antivirus y sistemas de detección (EDR) detectan los *payloads* y módulos estándar de Metasploit. Requiere técnicas de evasión para usarse en entornos modernos.
- **Versión Gratuita vs. Pro:** La versión gratuita es la framework con ella se trabaja por medio de la línea de comandos. La versión comercial (Metasploit Pro) tiene una interfaz gráfica, automatización y reportes, pero es muy costosa.
- **No es fácil de usar:** Aunque ayuda a simplificar la explotación, requiere un entendimiento y conocimientos técnicos previos de las áreas de redes, protocolos y sistemas operativos para usarla eficazmente. [7]

2.4 ¿Como defenderse de Metasploit?

Una forma de mitigar el uso de Metasploit es la defensa contra exploits que suelen ser muy utilizados. Por ejemplo una de las mejores estrategias es un sólido programa para la gestion de parches. Si mantenemos el sistema con todas sus actualizaciones de seguridad de una forma constante, la gran mayoría de los exploits que son publicos se vuelven inservibles.

3 Acunetix (DAST - Pruebas de Aplicaciones Web)

Acunetix es una herramienta commercial y que está automatizada por DAST, estas siglas significan Pruebas Dinámicas de Seguridad de Aplicaciones. Acunetix en palabras simples es un escaner de vulnerabilidades que está diseñado específicamente para detectar fallos de seguridad en aplicaciones, sitios web y API's. Esta herramienta simula un ataque externo, donde se intenta romper la aplicación desde fuera, esto sin la necesidad de ver el código fuente.

3.1 Usos y aplicaciones

El enfoque principal de Acunetix es detectar y encontrar nuevas vulnerabilidades:

Detección de OWASP: Es experto en encontrar las vulnerabilidades más críticas, como:

- Inyección SQL (SQLi)
- Cross-Site Scripting (XSS)
- Server-Side Request Forgery (SSRF)
- Inclusión de Archivos (LFI/RFI)

Escaneo de APIs: Prueba APIs REST, SOAP y GraphQL en busca de fallos de autenticación o lógica.

Escaneo de Single Page Applications (SPAs): Puede escanear aplicaciones modernas construidas con frameworks como React, Angular o Vue.js, que son difíciles para escáneres más antiguos.

Integración DevSecOps: Se integra en pipelines de CI/CD para escanear aplicaciones automáticamente antes de que pasen a producción.

3.2 Ventajas

- **Alta Precisión (Bajos Falsos Positivos):** Es muy bueno para confirmar vulnerabilidades, reduciendo el tiempo de verificación manual.
- **Velocidad:** Es uno de los escáneres DAST más rápidos del mercado.
- **Interfaz de Usuario (UI) Sencilla:** Es muy fácil de usar, configurar escaneos y generar reportes ejecutivos.
- **Tecnología IAST (AcuSensor):** Ofrece un sensor opcional (IAST) que se instala en el servidor para dar un análisis "desde dentro" y "desde fuera" a la vez, mejorando la detección.

3.3 Desventajas

- **Comercial (Costoso):** Es una herramienta de pago y su licencia puede ser cara para individuos o pequeñas empresas.
- **Enfoque Limitado:** Está 100% enfocado en la web. No es la herramienta ideal para escanear tu infraestructura de red (servidores, routers).
- **No ve el Código:** Al ser DAST puro, puede pasar por alto vulnerabilidades que solo son visibles analizando el código (SAST).
- **"Caja Negra":** Al ser un producto comercial, su funcionamiento interno no es modificable.

3.4 ¿Como defenderse de Acunetix?

La defensa más efectiva contra Acunetix es arreglar siempre los códigos de la aplicación, esto lo podemos lograr de distintas formas:

- **Consultas Parametrizadas:** Usar *prepared statements* para prevenir Inyección SQL.
- **Codificación de Salidas:** Codificar los datos del usuario antes de mostrarlos en HTML para prevenir XSS.

- **Validación de Entradas:** Rechazar cualquier dato del usuario que no tenga el formato esperado.
- **Actualización de Software:** Mantener al día *frameworks*, librerías (como JQuery) y servidores web (Apache, Nginx).
- **Cabeceras de Seguridad:** Implementar cabeceras HTTP como CSP (Content Security Policy).

4 OpenVas Escáner de Red e Infraestructura

OpenVas es un framework de código abierto utilizado para el escaneo de vulnerabilidades, OpenVas es el sucesor de Nessus, después de que este se volviera comercial.

La especialidad de esta herramienta es el escaneo de infraestructura y de red, esto para buscar y detectar vulnerabilidades conocidas CVEs en los sistemas operativos y servicios.

4.1 Usos y aplicaciones

El enfoque principal de OpenVas es detectar vulnerabilidades a nivel de red y de infraestructura:

- **Auditoría de Red:** Escanea rangos de IP para descubrir qué hosts están activos, qué puertos tienen abiertos y qué servicios (SSH, FTP, HTTP, SMB) están corriendo.
- **Detección de CVEs:** Compara las versiones del software y servicios encontrados (ej. "Apache 2.4.49") contra su enorme base de datos de vulnerabilidades conocidas (NVTs - Network Vulnerability Tests).
- **Análisis de Configuración:** Busca configuraciones inseguras, como permisos incorrectos, uso de contraseñas débiles (en servicios como FTP) o certificados SSL obsoletos.
- **Gestión de Parches:** Es fundamental para que los administradores de sistemas sepan qué servidores necesitan actualizaciones de seguridad urgentes.

4.2 Ventajas

- **Cobertura Masiva de Red:** Su base de datos de pruebas (NVTs) es extensa y se actualiza diariamente, cubriendo miles de CVEs en todo tipo de software (Linux, Windows, Cisco, etc.).
- **Personalizable:** Al ser *open source*, se puede adaptar, modificar e integrar con otras herramientas de forma muy flexible.
- **Reportes Detallados:** Ofrece reportes muy técnicos sobre las vulnerabilidades encontradas y cómo solucionarlas.

4.3 Desventajas

- **Falsos Positivos:** Tiende a generar más falsos positivos que las herramientas comerciales, requiriendo más verificación manual.
- **Enfoque de Red, no de Aplicación:** Aunque puede escanear un servidor web (puerto 80/443), no está diseñado para entender la lógica de una aplicación web (iniciar sesión, probar formularios).
- **Interfaz (GSA):** La interfaz web (Greenbone Security Assistant) es potente pero menos intuitiva que la de Acunetix.

4.4 ¿Como defenderse de OpenVas?

La defensa efectiva contra OpenVas no consiste en bloquear el escáner, sino en utilizar sus reports para remediar las vulnerabilidades detectadas.

- **Gestión de Parches:** Es la defensa número uno. Actualizar inmediatamente el software obsoleto que OpenVas reporta.
- **Cerrar Puertos (Mínimo Privilegio):** Usar un *firewall* para cerrar todos los puertos que no sean estrictamente necesarios
- **Deshabilitar Servicios Innecesarios:** Apagar servicios que no se usen (como FTP, Telnet, SMB).
- **Configuraciones Seguras:** Bastonar los servicios que sí se usan deshabilitar el *login* de root por contraseña en SSH.
- **Monitoreo Continuo:** Ejecutar escaneos de vulnerabilidad periódicamente.

5 Conclusiones

Al concluir con el análisis de estas tres herramientas, nos hace reflexionar en la importancia de prevenir ataques como los que se pueden realizar con estas mismas. Ya que estos ataques rara vez se suelen hacer una única vez.

El uso de estas herramientas nos demuestra la gran capacidad que puede tener un atacante para poder escalar un ataque, ya sea desde simplemente querer adivinar una contraseña, hasta poder tener control total del sistema o el robo de las llaves de usuario lo que permite poder moverse por la red objetivo libremente.

Sin embargo, lo más importante no es solo el poder de estas herramientas, sino también el como podemos defenderlas, Aunque estas herramientas sean muy potentes, esto no significa que no sean infalibles, ya que existen medidas simples como el uso de un antivirus, bloqueo de credenciales o el uso de autenticación para prevenirlos.

En definitiva, se nos demuestra que el conocimiento de las herramientas que usan los atacantes en la ciberseguridad es fundamental para tener una seguridad en nuestros sistemas sólidos. La defensa en la ciberseguridad no es algo tan simple como la gente piensa, sino todo lo contrario es un proceso de continua vigilancia, actualización y fortalecimiento de sistemas.

Bibliografía

- Choice), T. (. (11 de Marzo de 2024). *thc-hydra* (Repositorio de GitHub). Obtenido de GitHub: <https://github.com/vanhauser-thc/thc-hydra>
- gentlekiwi. (18 de Mayo de 2025). *blog de gentlekiwi*. Obtenido de gentlekiwi.com: <https://blog.gentlekiwi.com/>
- gentlekiwi. (27 de Septiembre de 2025). *mimikatz* (Repositorio de GitHub). Obtenido de GitHub: <https://github.com/gentlekiwi/mimikatz>
- Linux, K. (21 de Julio de 2024). *Hydra* (Kali Linux Tools). Obtenido de Kali.org: <https://www.kali.org/tools/hydra/>
- Rapid7. (9 de Noviembre de 2025). *Metasploit Documentation*. Obtenido de Metasploit Docs: <https://docs.metasploit.com/>
- Rapid7. (11 de Agosto de 2025). *Metasploit Penetration Testing Software*. Obtenido de Metasploit.com: <https://www.metasploit.com/>
- Rapid7. (1 de Octubre de 2025). *metasploit-framework* (Repositorio de GitHub). Obtenido de GitHub: <https://github.com/rapid7/metasploit-framework>